Lab 12 — Vulnerability Scanning with Nikto and Nuclei

You will scan a deliberately weak local web server with two free scanners, prioritise findings by CVSS, and re-scan to verify remediation.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free, apt + binary): - `nikto` - `apache2` - `nuclei` (single Go binary)

Step 1 — Install scanner and target

```
apt update && apt install -y nikto apache2 wget
```

```
systemctl start apache2
```

```
echo "<h1>Test</h1>" > /var/www/html/index.html
```

```
curl -sI http://127.0.0.1 | head
```

Step 2 — Run Nikto (web vulnerability scanner)

```
nikto -h http://127.0.0.1 -o nikto.txt
```

```
head -40 nikto.txt
```

Look for findings such as: - "Server may leak inodes via ETags" - "X-Frame-Options header is not present" - "Server banner discloses version"

Step 3 — Install nuclei (template-based scanner)

```
wget -q https://github.com/projectdiscovery/nuclei/releases/download/v3.10.0/nuclei_3.10.0_linux_amd64.zip
```

```
apt install -y unzip && unzip -o nuclei_3.10.0_linux_amd64.zip
```

```
./nuclei -update-templates -silent
```

Step 4 — Scan with severity filter

```
./nuclei -u http://127.0.0.1 -s low,medium,high,critical -o nuclei.txt
```

```
cat nuclei.txt
```

Each finding includes a CVE / CVSS where applicable.

Step 5 — Prioritise with CVSS

For each finding write:

Finding		Exploitability	
Missing HSTS header	5.3	Easy	Medium
Server banner leak	3.1	Info-only	Low
Outdated Apache	7.5	RCE in PoC	High

Patch high first, then medium.

Step 6 — Remediate the easy wins

```
cat > /etc/apache2/conf-available/hardening.conf <<'EOF'
```

```
ServerTokens Prod


ServerSignature Off


Header always set X-Frame-Options "SAMEORIGIN"


Header always set X-Content-Type-Options "nosniff"


Header always set Strict-Transport-Security "max-age=31536000"


EOF


a2enmod headers


a2enconf hardening


systemctl reload apache2
```

Re-run nikto and confirm those findings are gone.

```
nikto -h http://127.0.0.1 | grep -E "X-Frame|HSTS|banner"
```

Free online tools

- **NVD CVE database** — https://nvd.nist.gov
- **CVSS v3.1 calculator** — https://www.first.org/cvss/calculator/3.1
- **Mozilla Observatory** — https://observatory.mozilla.org
- **SecurityHeaders.com** — https://securityheaders.com
- **Nuclei templates registry** — https://cloud.projectdiscovery.io
- **Greenbone Community OpenVAS** — https://www.greenbone.net

---

What you learned

- How template-based scanners (nuclei) complement signature scanners (nikto).
- How to convert raw findings into a CVSS-prioritised remediation queue.
- That hardening headers fix the bulk of common web findings in one config.